Adaptive Multi-Tier IPS for IoT in SD-WAN

Project Assessment — Strengths, Weaknesses & Real-World Fit

4-tier detection (Snort · rate/DAI · Random Forest · Autoencoder) on a Ryu SDN controller, deployed on an HP t530 thin client.

Graduation Project reference note · Prepared 15 August 2026

This note is a quick-reference summary of where the project is strong, where it is limited, and how well it maps to real deployments. It is written to be read cold — to refresh the full picture before a review, a thesis defense, or a decision about productization.

1 System at a glance

An in-network Intrusion Prevention System for IoT traffic. Packets are mirrored to a Ryu controller over an Open vSwitch data plane; four detection tiers score each flow and, when a threat is confirmed, the controller installs a DROP at the switch (OpenFlow) or the host firewall (iptables). Enforcement is deliberately gated: signatures/rate by a DETECT switch, the ML tiers by an OBSERVE→AUTHORIZE mode with confidence bands.

Tier	Detects	Blind spot (covered by other tiers)
Tier 1 — Snort 3	Signature match on known attack patterns	Unknown / zero-day attacks with no signature
Tier 2 — Rate + DAI	Volumetric floods & ARP spoofing (Dynamic ARP Inspection)	Low-and-slow, non-volumetric attacks
Tier 3 — Random Forest	Supervised classification of known attack classes on flow features	Classes absent from the training set
Tier 4 — Autoencoder	Unsupervised anomaly / zero-day (trained on normal only)	Attacks that mimic normal traffic; threshold-sensitive

Platform: Ryu (OpenFlow 1.0) + Open vSwitch · HP t530 thin client · REST/UDP control + web dashboard · config-driven LAN classification, protected-MAC allowlist, timed/permanent blocks, and a pre-production data-collection + retraining pipeline.

2 Strengths

Strength	Why it matters
Layered defense in depth	Four complementary tiers — each covers another's blind spot, so there is no single detection method an attacker can bypass to get through.
Zero-day detection	The autoencoder is trained on *normal traffic only*, so it flags novel attacks that have no signature — the core gap in signature-only IDS.
SDN-native enforcement	One controller can DROP any host at the switch, programmatically and centrally, with control and data planes decoupled.
Agentless & IoT-appropriate	Purely network-based — needs no software on the device, so it fits unpatched, proprietary, any-vendor IoT that can't run endpoint agents.
Privacy-preserving detection	Scores flow statistics and entropy, not packet payloads/DPI — it never inspects sensitive content, a genuine data-protection advantage.
No train/serve skew	The *same* traffic-capture code produces both the training dataset and the live features — structurally preventing a classic ML-ops failure mode.

Strength	Why it matters
Graduated, safe enforcement	DETECT vs ML gating, OBSERVE→AUTHORIZE, confidence bands, protected-MAC allowlist, timed/permanent blocks with real unblock — production-grade caution.
Concurrency-correct core	A hub-safe block queue solves the eventlet threading hazard that most SDN controllers get wrong, so enforcement doesn't deadlock under attack.
Adaptive / retrainable	A pre-production collection + retrain pipeline lets the models be fitted to a new network's real normal before blocking is ever enabled.
Low-cost commodity hardware	Runs on an inexpensive HP t530 thin client — no specialized appliance or accelerator required.

3 Weaknesses & limitations

Limitation	Impact / what it means
Placement & visibility limits	It only sees traffic that physically crosses it; two devices on the same dumb switch (east-west) are invisible, and the single-NIC t530 needs a second port for true inline blocking.
No application-layer (L7) inspection	Blind to web attacks — SQLi, XSS, RCE, path traversal — which ride valid TCP flows. This is the motivation for the firewall/WAF integration plan.
Encrypted traffic is opaque	It cannot inspect TLS payloads and relies on metadata/behavior only, a shrinking window as more traffic is encrypted end-to-end.
Trained on a simulated testbed	Mininet traffic (with a 2× mirror double-count) differs from real devices; models must be retrained on real traffic first, or they false-positive on legitimate devices.
Supervised-model & dataset dependence	The Random Forest only recognizes labeled classes; accuracy drifts as traffic evolves, so periodic retraining is required.
Adversarial robustness untested	Low-and-slow, traffic-mimicry, MAC/IP spoofing, and baseline poisoning during the learning window are not specifically hardened against.
Single controller = single point of failure	No high-availability or clustering; if the controller dies you either fail-open (no protection) or fail-closed (no traffic).
Scale ceiling	Ryu on one thin client, packet-in-to-controller ML, and Random Forest forced to a single thread cap throughput — suited to SMB/branch, not datacenter scale.
Legacy OpenFlow 1.0	Limited match fields and IPv6 richness; MAC/IP-based DROP can be evaded by spoofing the identifier.
Operational fragility / manual MLOps	Pinned scikit-learn, Snort 3 from source, and eventlet quirks make the runtime finicky; a full autoencoder retrain needs the training notebook, and there is no automated model lifecycle.

4 Real-world applicability

Where it fits well

- Small-business, home, smart-home and smart-factory IoT LANs with many unmanaged devices.
- Branch / edge sites in an SD-WAN, where an in-network sensor + enforcer is valuable.
- Environments where endpoint agents are impossible (medical, industrial, consumer IoT).
- As a Network Detection & Response (NDR) sensor feeding a wider security stack.
- Research / teaching testbeds for SDN security and ML-based detection.

Realistic deployment shapes

- **Inline transparent bridge** (two NICs) — full prevention, bump-in-the-wire.
- **SPAN / mirror monitor** (one NIC) — detection-only; blocking becomes best-effort.

- **SDN-native** — where Open vSwitch is already the switch, enforcement is native.
- **Decision brain** — driving an existing firewall / WAF via its API (the integration plan).

Market context & maturity

The concept matches an established commercial category — agentless IoT/IoMT network detection & response (Armis, Claroty/Medigate, Cynerio, Ordr) — which both *validates* the idea and sets the bar (HA, scale, L7 coverage). Honest maturity: a **strong research prototype / POC with real deployment engineering**, roughly **TRL 4–5** (validated in a relevant lab environment, early field transition) — not yet a hardened commercial product.

5 Compatibility matrix

Dimension	Today	Real-world need	Fit
Device coverage	Agentless, any-vendor	Mixed unmanaged IoT	**Strong**
Attack coverage	L2–L4 (sig / rate / ML / AE)	+ L7 web attacks	**Partial**
Traffic visibility	What crosses the box	Full, incl. east-west	**Partial**
Encrypted traffic	Metadata / behavior only	Growing TLS share	**Partial**
Enforcement	OpenFlow + iptables	Managed FW + WAF + SDN	**Partial**
Availability / HA	Single controller	Redundant, fail-safe	**Gap**
Scale	SMB / branch	Enterprise / datacenter	**Partial**
Adaptivity	Retrainable (manual)	Continuous learning	**Partial**
Cost / hardware	Commodity thin client	—	**Strong**

Strong = ready today · **Partial** = works but needs extension · **Gap** = must be addressed before critical-production use.

6 Bottom line

The core of the project — layered, ML-augmented, SDN-native, agentless detection with cautious graduated enforcement — is genuinely strong and well-matched to IoT, small-business and branch networks. The engineering behind it (no train/serve skew, hub-safe concurrency, config-driven deployment, retraining pipeline) is clearly above typical student-project level. The readiness gaps are the well-understood ones: application-layer coverage, encrypted-traffic and adversarial robustness, high availability and scale, and the need to retrain on real traffic before enforcing. None are conceptual dead-ends — they are the standard prototype→product hardening path.

Top 3 moves to raise real-world readiness

1. **Retrain on real network traffic** and validate at rest (OBSERVE→AUTHORIZE) before enabling any blocking — the single biggest false-positive fix.
2. **Add L7 coverage (WAF) and a managed firewall** driven by the same detection brain — see *firewall_waf_integration_plan.md*.
3. **Address availability and adversarial robustness** — controller HA / a defined fail-open policy, plus testing against evasion and baseline poisoning.